CYBERSECURITY TRACK • PHP & WEB MODULE

Assignment 13

Secure Session & Cookie Management Tool (PHP)

Done by: Abdulhadi Al-Ahdal

1. Project Overview

Develop a PHP authentication and session fixation prevention script aimed at protecting Session IDs and cookies from theft via XSS or CSRF attacks[cite: 7]. The tool issues secure cookies equipped with strict protection attributes like HttpOnly and SameSite to prevent client-side JavaScript access[cite: 7].

2. Development Steps

1 Session Cookie Parameter Setup

Configure default security parameters via `session_set_cookie_params()` prior to startup[cite: 7].

2 HttpOnly Enforcement

Apply `httponly => true` to block reading cookies through browser `document.cookie` [cite: 7].

3 SameSite Strict Configuration

4 Session Regeneration

Utilize the `samesite => 'Strict'` attribute to mitigate Cross-Site Request Forgery (CSRF) attacks[cite: 7].

Execute `session_regenerate_id(true)` following authentication to prevent Session Fixation[cite: 7].

3. Technical Features & Utilities

Options Array in setcookie: Pass options arrays instead of legacy string arguments to `setcookie()` [cite: 7].

Header Verification: Inspect server response headers for `Set-Cookie` to ensure flags like HttpOnly and Secure are active[cite: 7].

4. Implementation Source Code

`secure_session.php`

PHP 8.x

```php
<?php
// Configure secure session parameters before starting session
session_set_cookie_params([
    'lifetime' => 0,
    'path' => '/',
    'domain' => '',
    'secure' => true,      // Requires HTTPS
    'httponly' => true,    // Blocks JavaScript document.cookie access
    'samesite' => 'Strict' // Mitigates CSRF vulnerabilities
]);

session_start();
```

```php
// Prevent Session Fixation upon login simulation
if (!isset($_SESSION['initialized'])) {
    session_regenerate_id(true);
    $_SESSION['initialized'] = true;
    $_SESSION['user'] = "Abdulhadi";
}

// Issue an extra custom secure cookie using options array
setcookie("SecureAuthToken", "xyz987securetokenvalue", [
    'expires' => time() + 3600,
    'path' => '/',
    'secure' => true,
    'httponly' => true,
    'samesite' => 'Strict'
]);

header("Content-Type: application/json; charset=UTF-8");
echo json_encode([
    "status" => "success",
    "message" => "Secure session and cookies established with HttpOnly and SameSite=Strict flags.",
    "session_id" => session_id(),
    "session_user" => $_SESSION['user']
], JSON_PRETTY_PRINT);
?>
```

5. Acceptance Criteria

- ✓ **HttpOnly Enforcement Verified**
- ✓ **Stable Session Regeneration**

Issuance of cookies with HttpOnly flags preventing direct JavaScript inspection and theft[cite: 7].

Successful regeneration of session IDs and stable authentication management across page transitions[cite: 7].